

SOC L1 Playbook – Phishing detection

8/15/2025

Lovish Ramphul

Table of Contents

Phishing.....	2
Mitigation strategies include:	2
Email Authentication Protocols	2
Tools for IOC Analysis:.....	3
Phishing Email Sample	3
View Full Email Headers.....	4
Extracted Indicators of Compromise (IOCs) – Phishing Email Analysis.....	4
SOC Analyst Checklist.....	6
Supplement IOC Analysis with Other Tools	7
WHOIS LOOKUP	7
MxToolbox Analysis	8
SOC Takeaways:	9
SOC L1 Handling Guidelines	10

SOC L1 Playbook: Detecting & Responding to Phishing Emails

Phishing is a social engineering attack where attackers impersonate trusted entities to deceive victims into revealing sensitive information. Typically, phishing emails contain malicious links or attachments that redirect the victim to fraudulent websites mimicking legitimate services. Submitted credentials (usernames, passwords, financial details) are captured for malicious purposes such as:

- Credential theft
- Unauthorized access
- Financial fraud

Compromised credentials may be used to escalate privileges, move laterally in target systems, exfiltration data, or launch identity theft. Phishing emails may also contain malware attachments (e.g., backdoors or RATs) granting persistent remote access.

Mitigation strategies include:

- Implementing multi-factor authentication (MFA)
- Deploying advanced email security solutions: SPF, DKIM, DMARC, and phishing filters
- Regular user training on identifying suspicious emails and phishing tactics

Three types of email authentication:

Email Authentication Protocols

1. SPF (Sender Policy Framework)

- Verifies if the sending mail server is authorized to send emails on behalf of the domain.
- Domains maintain a list of allowed sending servers.
- Emails from unauthorized servers may be rejected, flagged, or quarantined.

2. DKIM (DomainKeys Identified Mail)

- Ensures email integrity and verifies the sender's identity.
- The sender signs the email with a private key; the public key is published in DNS.
- Recipients verify the signature to confirm authenticity and prevent tampering.

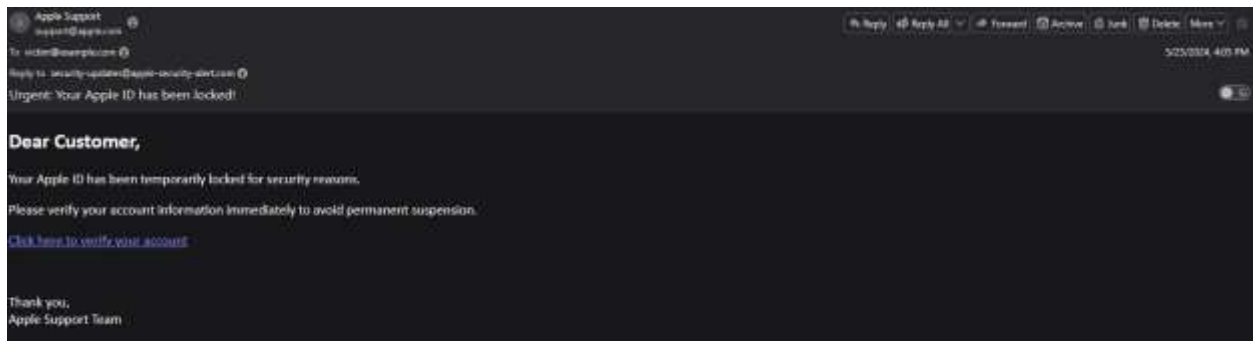
3. DMARC (Domain-based Message Authentication, Reporting, and Conformance)

- Uses SPF and DKIM results to enforce a policy: reject, quarantine, or flag emails failing authentication.

Tools for IOC Analysis:

Tool	Purpose
VirusTotal	Scans files, URLs, IPs, and domains against malware and blacklists.
URLScan.io	Performs dynamic sandbox analysis of URLs to detect phishing, malware, or suspicious behavior.
MXToolBox	Queries DNS, MX, SPF, DKIM, and DMARC records; checks blacklists and mail server configuration.
WHOIS Lookup	Retrieves domain registration metadata including registrant info, creation/expiration dates, and nameservers.

Phishing Email Sample



View Full Email Headers

```
X-Mozilla-Status: 0001
X-Mozilla-Status2: 00000000
X-Mozilla-Keys:
Return-Path: <random123@gmail.com>
Received: from mail.fakeapple.com (mail.fakeapple.com [192.0.2.1])
  by smtp.emailserver.com (Postfix) with ESMTP id 1234ABCD
  for <victim@example.com>; Sat, 25 May 2024 12:05:23 +0000 (UTC)
From: Apple Support <support@apple.com>
Reply-To: security-updates@apple-security-alert.com
To: <victim@example.com>
Subject: Urgent: Your Apple ID has been locked!
Date: Sat, 25 May 2024 12:05:23 +0000
Message-ID: <20240525120523.12345@mail.fakeapple.com>
MIME-Version: 1.0
Content-Type: text/html; charset=UTF-8

<html>
  <body>
    <h2>Dear Customer,</h2>
    <p>Your Apple ID has been temporarily locked for security reasons.</p>
    <p>Please verify your account information immediately to avoid permanent suspension.</p>
    <p><a href="http://apple.verify-account-security.com/login">Click here to verify your account</a></p>
    <br>
    <p>Thank you,<br>Apple Support Team</p>
  </body>
</html>
```

Extracted Indicators of Compromise (IOCs) – Phishing Email Analysis

1. Return-Path

Purpose: Address where error messages are sent if the email can't be delivered.

SOC Relevance: Often reveals the attacker's real email; mismatches with "From" are suspicious.

Extracted IOC:

random123@gmail.com

Observation: Gmail address not related to Apple → strong phishing indicator.

2. From Address

Definition: Sender name/address shown to the recipient in their inbox.

SOC Relevance: If domain differs from Return-Path, possible spoofing.

Extracted IOC:

Apple Support <support@apple.com>

Observation: Appears legitimate, but Return-Path mismatch indicates spoofing.

3. Reply-To

Definition: Address that receives replies when the user clicks “Reply.”

SOC Relevance: Attackers often use this to redirect replies to their own inbox.

Extracted IOC:

security-updates@apple-security-alert.com

Observation: Domain unrelated to Apple; registered likely for phishing.

4. Sending Domain

Definition: Actual domain of the mail server sending the message (from “Received” headers).

SOC Relevance: Check against SPF/DKIM/DMARC to verify legitimacy.

Extracted IOC:

mail.fakeapple.com

Sending IP: 192.0.2.1 (RFC 5737 test IP – fake in this sample)

Observation: Not part of Apple’s infrastructure.

5. Subject

Extracted IOC:

[Urgent: Your Apple ID has been locked!](#)

Observation: Urgency and account lock threat — classic phishing tactic.

6. Body Content

Extracted IOC:

<http://apple.verify-account-security.com/login>

Observation:

Domain not owned by Apple.

Uses HTTP (not HTTPS), insecure.

Likely hosts phishing login page for credential theft.4

7. SPF/DKIM/DMARC Context

SPF: Verifies sending server is authorized for domain.

DKIM: Ensures message integrity and authentic origin.

DMARC: Specifies action (reject/quarantine) if SPF/DKIM fail.

Relevance: In this case, SPF/DKIM would likely fail for apple.com from mail.fakeapple.com.

SOC Analyst Checklist

Compare Return-Path, From, and Reply-To → mismatches detected.

Check Sending Domain in Received headers → not authorized by SPF/DKIM.

Inspect links in email body → points to suspicious, non-Apple domain.

Mark as Confirmed Phishing and proceed with blocking & incident response.

Analyze IOCs Using VirusTotal

IOC Type	Value	Source in Email	Purpose in Attack	VirusTotal Detection	SOC Action
Return-Path Email	random123@gmail.com	Return-Path header	Attacker's bounce/reply address	N/A	Flag & block sender address
From Address	support@apple.com	From header	Spoofed branding to appear legitimate	N/A	Check SPF/DKIM mismatch
Reply-To Email	security-updates@apple-security-alert.com	Reply-To header	Redirects victim replies to attacker-controlled inbox	N/A	Flag & block domain
Sending Domain	mail.fakeapple.com	Received header	SMTP server domain used to send phishing email	0/97 Clean	Add to watchlist, check against RBLs
Sending IP	192.0.2.1	Received header	IP of sending mail server	0/97 clean	Check against RBLs & block

Phishing Link Domain	apple.verify-account-security.com	Email body link	Credential harvesting landing page	1/97 Malicious (ESET: Phishing)	Block on proxy/email filter
Phishing URL	http://apple.verify-account-security.com/login	Email body link	Full phishing page URL	1/97 Malicious	Block & add to IOC feeds

Supplement IOC Analysis with Other Tools

WHOIS LOOKUP to see the list of dns record for apple

apple.com

DNS Records

Whois

RDAP

DNS Records

Uptime

Diagnostics

Hide Data

DNS Records for apple.com

Hostname	Type	TTL	Priority	Content
apple.com	NS	0		c.ns.apple.com
apple.com	NS	0		a.ns.apple.com
apple.com	NS	0		b.ns.apple.com
apple.com	NS	0		d.ns.apple.com
apple.com	AAAA	0		2620:149:af0::10
apple.com	A	0		17.253.144.10
apple.com	MX	0	20	mx-in-sg.apple.com
apple.com	MX	0	20	mx-in-ma.apple.com
apple.com	MX	0	20	mx-in-vib.apple.com
apple.com	MX	0	20	mx-in-hfd.apple.com
apple.com	MX	0	10	mx-in.g.apple.com
apple.com	MX	0	20	^ mx-in-rn.apple.com

So the [support@apple.com](#) is not in the list meaning it is a fake mail server which can be a sign of phishing attack.

MxToolbox Analysis: [verify-account-security.com](#)

9 Problems

Category	Host	Result	
http	verify-account-security.com	The remote name could not be resolved: 'verify-account-security.com' (http://verify-account-security.com)	More Info
dmarc	verify-account-security.com	No DMARC Record found	More Info
mx	verify-account-security.com	DNS Record not found	More Info
mx	verify-account-security.com	No DMARC Record found	More Info
mx	verify-account-security.com	DMARC Quarantine/Reject policy not enabled	More Info
spf	verify-account-security.com	No SPF Record found	More Info
spf	verify-account-security.com	No DMARC Record found	More Info
spf	verify-account-security.com	DMARC Quarantine/Reject policy not enabled	More Info
dns	verify-account-security.com	DNS Record not found	More Info

Issue	Details	SOC Relevance
HTTP – Remote name could not be resolved	Domain has no valid DNS entry	Typical phishing tactic; short-lived or inactive domains
DMARC – No record / Quarantine/Reject not enabled	No DMARC policy	Strong signal of phishing / not legitimate
MX / DNS – No MX / Record not found	Cannot receive emails	Domain likely hosts phishing pages only
SPF – No record	Sending servers not defined	Easy to spoof → phishing indicator
DNS Record not found	Domain inactive or never legitimate	Confirms phishing suspicion

SOC Takeaways:

- Domain shows all classic phishing signs: no MX, SPF, DMARC, possibly short-lived.
- Combine with header mismatches → confirms phishing.
- **Recommended Actions:**
 - Block domain and URL in email gateway/proxy

- Add to IOC list for SIEM alerts (e.g., Splunk)
 - Alert users not to click links
-

SOC L1 Handling Guidelines

1. If clearly malicious:

- Block domain/URL in gateway/proxy
- Add to IOC list for SIEM
- Alert users

2. If suspicious but unclear:

- **Escalate to L2/L3 with evidence:**
 - Email headers (Return-Path, From, Reply-To, Received)
 - MXToolBox results
 - VirusTotal/URL reputation analysis
 - SPF/DKIM/DMARC checks

3. If clean / false positive:

- Close incident
- Document all findings and actions